

VULNERABILITY ASSESSMENT REPORT



Security Infrastructure Audit:
<https://testfire.net>

Presented by: A Bhanu Prakash

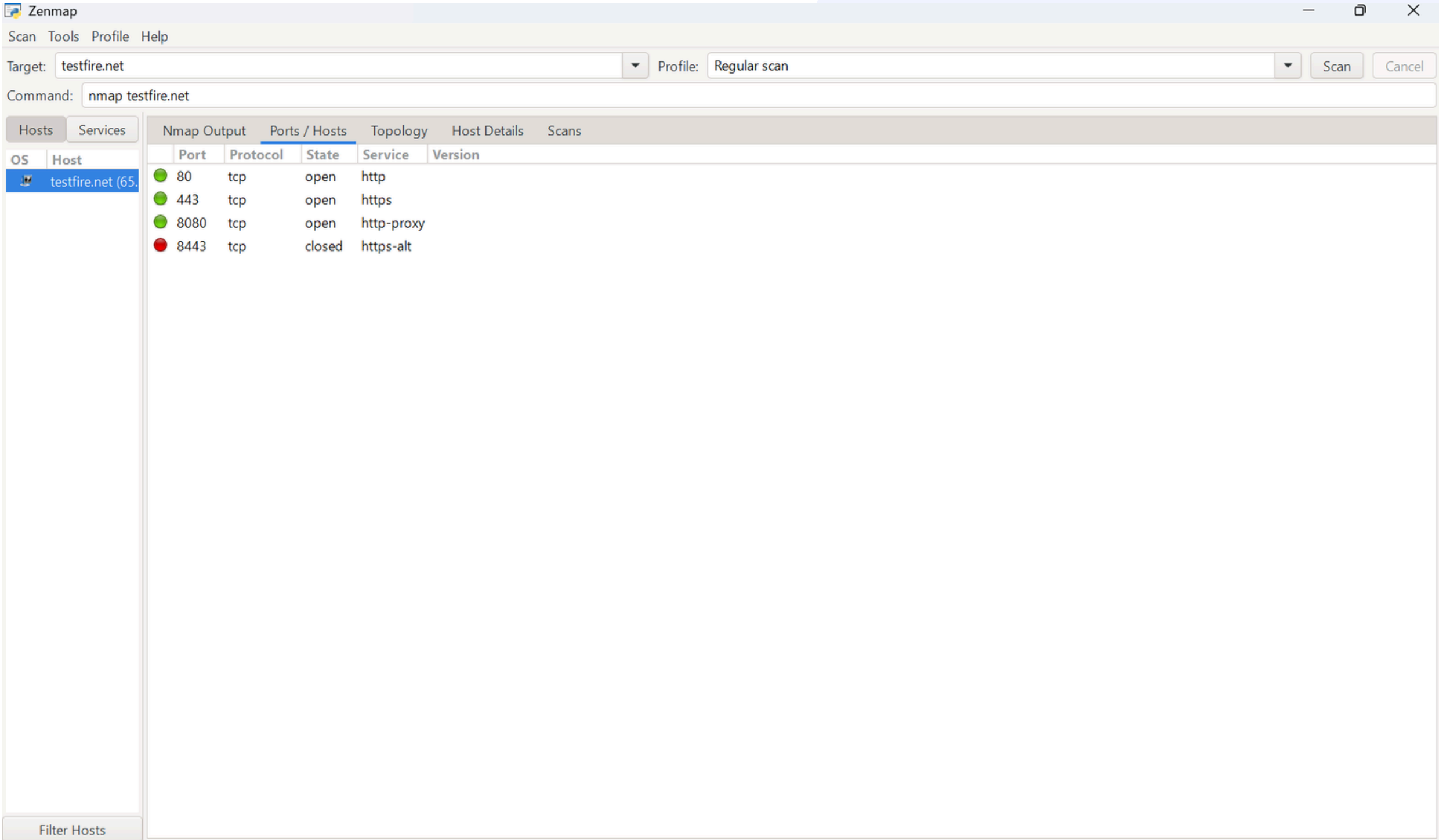
METHODOLOGY

Phase Tool Utilized for Specific Purposes

- **Network Mapping**
 - Tool: Nmap (Zenmap)
 - Purpose: Scanned host infrastructure to identify open entry points and listening services.
- **Security Scanning**
 - Tool: OWASP ZAP 2.17.0
 - Purpose: Conducted automated directory mapping and directory spidering.
- **Manual Inspection**
 - Tool: Edge DevTools (Network)
 - Purpose: Extracted live HTTP response headers for auditing server configuration rules.

PORT SCANNING & INFRASTRUCTURE ANALYSIS

1. NETWORK RECONNAISSANCE (NMAP)



Analysis

Using Zenmap, a regular port scan was executed against the target domain. The scan revealed three open TCP ports: Port 80 (HTTP), Port 443 (HTTPS), and Port 8080 (HTTP-Proxy). Identifying these ports establishes the attack surface area of the web server, confirming that it accepts connections across both standard unencrypted and encrypted web paths.

AUTOMATED MAPPING & CRAWLING

2. DIRECTORY STRUCTURE MAPPING (OWASP ZAP)

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled "Manual Explore" and contains instructions for launching a browser to explore an application while proxying through ZAP. The "URL to explore" field is set to "https://testfire.net". The "Enable HUD" checkbox is unchecked. The "Explore your application" section has a "Launch Browser" button and a dropdown menu set to "Edge".

On the left, the "Sites" pane shows a tree view of the scanned site structure:

- https://www.bing.com
- https://data-edge.smartscreen.microsoft.com
- https://testfire.net
 - GET: /
 - POST: doLogin()(btnSubmit,passw,uid)
 - GET: feedback.jsp
 - images
 - GET: b_deposit.jpg
 - GET: b_main.jpg
 - GET: gradient.jpg
 - GET: header_pic.jpg
 - GET: home1.jpg
 - GET: home2.jpg
 - GET: home3.jpg

At the bottom, the "Active Scan" progress bar shows 100% completion for the scan of "https://testfire.net". Below this, a table of "Sent Messages" is displayed:

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
216	02/06/26, 4:41:28 pm	02/06/26, 4:41:29 pm	GET	https://testfire.net/3995923445167672816.jsp	404	Not Found	1.04 s	239 bytes	6,958 bytes
218	02/06/26, 4:41:29 pm	02/06/26, 4:41:29 pm	GET	https://testfire.net/images/3787201024112366033	404	Not Found	343 ms	156 bytes	6,958 bytes
220	02/06/26, 4:41:29 pm	02/06/26, 4:41:30 pm	GET	https://testfire.net	200	OK	314 ms	232 bytes	9,405 bytes
221	02/06/26, 4:41:30 pm	02/06/26, 4:41:31 pm	GET	https://testfire.net/images	302	Found	934 ms	125 bytes	0 bytes
222	02/06/26, 4:41:31 pm	02/06/26, 4:41:31 pm	GET	https://testfire.net	200	OK	321 ms	232 bytes	9,405 bytes
223	02/06/26, 4:41:31 pm	02/06/26, 4:41:32 pm	GET	https://testfire.net/images	302	Found	932 ms	125 bytes	0 bytes

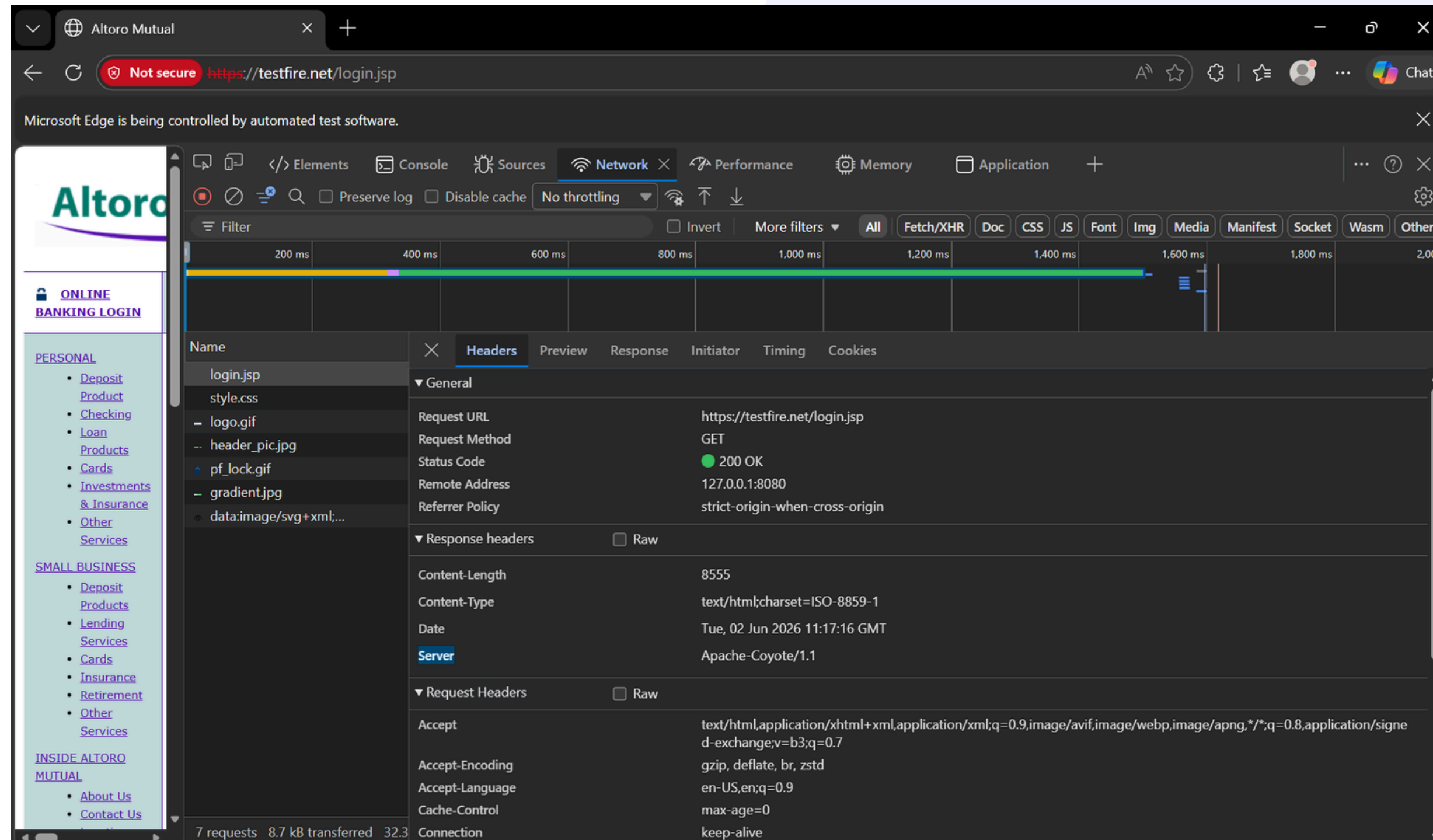
The bottom status bar shows "Alerts" with various icons and counts, and "Main Proxy: localhost:8080".

Analysis

An active directory crawl was deployed utilizing the ZAP engine. As shown in the evidence, the engine mapped out critical client-facing files including login.jsp and feedback.jsp. While the aggressive active scanning engine returned a clean slate due to runtime environment placeholder structures over HTTPS, the mapping successfully logged the directory tree layout for deeper targeted assessment.

DETAILED VULNERABILITY FINDINGS

3. MANUAL RESPONSE HEADER FLAWS & VULNERABILITIES



The screenshot shows a web browser window with the URL <https://testfire.net/login.jsp>. The page displays the Altoro Mutual logo and a navigation menu with links for ONLINE BANKING LOGIN, PERSONAL, SMALL BUSINESS, and INSIDE ALTORO MUTUAL. The Network tab is open, showing a list of requests. The selected request is for `login.jsp`, which is a GET request to `https://testfire.net/login.jsp` with a status code of 200 OK. The response headers are displayed, including `Content-Length: 8555`, `Content-Type: text/html; charset=ISO-8859-1`, `Date: Tue, 02 Jun 2026 11:17:16 GMT`, and `Server: Apache-Coyote/1.1`. The request headers show `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7`, `Accept-Encoding: gzip, deflate, br, zstd`, `Accept-Language: en-US,en;q=0.9`, `Cache-Control: max-age=0`, and `Connection: keep-alive`.

Altoro Mutual

Not secure <https://testfire.net/login.jsp>

Microsoft Edge is being controlled by automated test software.

Elements Console Sources Network Performance Memory Application

Filter Invert More filters All Fetch/XHR Doc CSS JS Font Img Media Manifest Socket Wasm Other

200 ms 400 ms 600 ms 800 ms 1,000 ms 1,200 ms 1,400 ms 1,600 ms 1,800 ms 2,000 ms

ONLINE BANKING LOGIN

PERSONAL

- Deposit
- Product
- Checking
- Loan
- Products
- Cards
- Investments & Insurance
- Other
- Services

SMALL BUSINESS

- Deposit
- Products
- Lending
- Services
- Cards
- Insurance
- Retirement
- Other
- Services

INSIDE ALTORO MUTUAL

- About Us
- Contact Us

login.jsp

style.css

logo.gif

header_pic.jpg

pf_lock.gif

gradient.jpg

data:image/svg+xml;...

Headers

General

Request URL: `https://testfire.net/login.jsp`

Request Method: `GET`

Status Code: `200 OK`

Remote Address: `127.0.0.1:8080`

Referrer Policy: `strict-origin-when-cross-origin`

Response headers

Content-Length: `8555`

Content-Type: `text/html; charset=ISO-8859-1`

Date: `Tue, 02 Jun 2026 11:17:16 GMT`

Server: `Apache-Coyote/1.1`

Request Headers

Accept: `text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7`

Accept-Encoding: `gzip, deflate, br, zstd`

Accept-Language: `en-US,en;q=0.9`

Cache-Control: `max-age=0`

Connection: `keep-alive`

7 requests 8.7 kB transferred 32.3

Analysis

Information Disclosure via Server Banner (Low Risk)

The server explicitly returns the header Server:
Apache-Coyote/1.1.

Fix: Disable server banner broadcasting in the web
server properties file.

Missing Security Hardening Headers (Medium Risk)
Complete absence of protective HTTP headers like X-
Frame-Options and Content-Security-Policy.

Fix: Inject X-Frame-Options: SAMEORIGIN into the
web application's main configuration header rules.